ACC-07 · Privileged & Administrative Account Standard

How the accounts that can change everything are created, authenticated, used and reviewed.

Field	Value
Document ID	ACC-07
Version	1.0 · Known Good edition, by Kevin Zelman
Catalogue domain	B. Account Usage
Operating tier	Tier 3 — Expert Services. Tier 4 approves every assignment.
Review cycle	Every six months.

1. Purpose

A privileged account can change the configuration everything else depends on. It is the account an attacker actually wants, and the population is small enough that stronger controls cost almost nothing to operate.

The most important practice is simple: administrative work is done from separate identities, usually on the onmicrosoft.com domain, rather than from ordinary staff accounts. This document writes down that practice and the rules that should go with it.

2. What counts as privileged

- Any Entra ID directory role — Global Administrator, User Administrator, Intune Administrator, Exchange Administrator, Helpdesk Administrator and the rest.
- Any role that can read a credential or a recovery key, including BitLocker recovery keys (DEV-03 §7).
- Domain and enterprise administration in on-premises Active Directory.
- Administrative access to the HR and user system of record, the ERP estate, the ticketing system, Intune, the network estate, and the telephony platform.
- Any account that can grant any of the above to somebody else. This is the one people forget, and it is the most powerful of the set. Vendor and partner administrative access — for example, an implementation partner on the HR system servers, or a managed security provider in the security tooling — is privileged access held by somebody outside the organization and is governed here together with ACC-11.

3. Separate identities

> **Administrative work is never done from a person's ordinary account.**
>
> A staff account reads email, opens attachments, browses the web and joins meetings. That is a large attack surface, and it is exactly the surface a phishing campaign targets. Attaching directory privilege to it means one successful phish is a tenant compromise rather than a mailbox compromise.
>
> A separate administrative identity does none of those things, which is what makes the control work.

Rule	Detail
Naming	One consistent pattern, for example initials plus SA on the onmicrosoft.com domain. Visually distinct from a mail-enabled staff account at a glance (ACC-02 §3).
No mailbox	Administrative identities are not mail-enabled and do not receive email. If one needs to receive a notification, that notification goes to the person's ordinary account or to a monitored address.
No licence beyond what the role requires	An administrative identity with a full productivity licence is an administrative identity somebody will start working from.
One per person	Never shared. A shared administrative account defeats every audit and makes the §10 records meaningless.
Not used for daily work	Sign in to it to do the administrative task, sign out afterwards. Where the tooling allows, use a separate browser profile so the two sessions cannot be confused.

4. Authentication

	Current state	Target state
Method	Phishing-resistant only — Windows Hello for Business, platform credential, or FIDO2 security key. SMS and voice are not permitted for privileged accounts in either state.	Unchanged. Privileged accounts move to phishing-resistant first, as Wave 0 of the ACC-03 §11.2 rollout.
Self-service reset	Not available. Never available.	Unchanged.
Recovery	Verified in person or by video (ACC-06 §8) — V1 or V2 only, no vouching, no callback.	Unchanged, with a Temporary Access Pass rather than a password.
Conditional Access	Privileged roles required to sign in from a compliant device.	Plus location and risk conditions as Conditional Access matures.

Privileged accounts go first in the phishing-resistant rollout for two reasons: they carry the most risk, and the people who will have to support everybody else through it should hit the problems first (ACC-03 §11.2).

5. Assigning a role

1. The request names the person, the role, the reason, and how long it is needed. “Ongoing” is an acceptable answer for a substantive job function and needs saying explicitly rather than assumed.
2. Tier 4 approves. Every assignment, including for Tier 3 staff and including for the Head of IT.
3. Grant the narrowest role that does the job. Global Administrator is not the answer to “they need to reset passwords” — Helpdesk Administrator is, and the difference matters. Where a built-in role is far broader than the need, build a custom role.
4. Assign to the person’s administrative identity, never to their staff account.
5. Where the platform supports just-in-time elevation, use it: the role is eligible rather than permanently active, and activation is requested, time-boxed and logged. This is the single largest reduction in standing privilege available and it should be the default for anything above Helpdesk Administrator.
6. Record the assignment, the approver, the reason and any end date.

6. Break-glass accounts

Two accounts exist so that the organization is never locked out of its own tenant — by a Conditional Access misconfiguration, a federation failure, or the unavailability of the people who normally hold access.

- Two, not one. A single break-glass account is a single point of failure at exactly the moment nothing else works.
- Cloud-only, permanently assigned Global Administrator, excluded from every Conditional Access policy — and that exclusion is tested before each policy goes live, not assumed (ACC-03 §11.1).
- Credentials split and held in sealed physical custody by two separate senior people, so no one person can use one alone.
- Excluded from MFA enforcement, which is why the physical custody matters.
- Sign-in generates an immediate alert to the Head of IT and to Tier 3. Any use is an incident until shown otherwise (GOV-03).
- Tested twice a year: sign in, confirm access, rotate credentials, reseal, record. An untested break-glass account is a break-glass account that does not work.

7. Using a privileged account

- Sign in, do the task, sign out. Do not leave a privileged session open alongside ordinary work.
- Do not read email, browse, or open documents from a privileged session.
- Record what you changed. Tenant configuration changes go through M365-21; device and network changes through GOV-04.
- Verify identity per ACC-06 before performing an account action for somebody else — privileged access does not exempt the holder from the verification gate. It makes it more important.
- Retrieving a recovery key or a credential is a recorded, audited act with a verified requester (DEV-03 §7).

8. Review

1. Quarterly, Tier 3 produces the full list of privileged assignments — who, what role, since when, approved by whom, and last used.
2. Tier 4 confirms each one is still required. Last-used is the most informative column: a role nobody has activated in six months is a role nobody needs.
3. Anything unconfirmed is removed. As everywhere else in this catalogue, silence is not approval.
4. Vendor and partner administrative access is reviewed in the same cycle, against the current contract.
5. The list of people who can read recovery keys is reviewed specifically, because it grows quietly and is easy to overlook (DEV-03 §7).
6. Break-glass credentials are tested and rotated twice a year, and that test is recorded.

9. Service levels

Activity	Commitment (per GOV-06)
New privileged role assignment	P3 — 3 coverage days, allowing for Tier 4 approval.
Just-in-time activation by an eligible holder	Immediate, self-service, logged.
Privileged account recovery, verified V1 or V2	P2 — 2 coverage hours.
Removal on separation or role change	Immediate. This is the highest-priority line of the leaver checklist.
Break-glass sign-in detected	P1 — treated as an incident until shown otherwise.
Quarterly review pack	Produced by Tier 3 on schedule.

10. Records

Record	Held in	Retention
Privileged assignment register: person, role, reason, approver, dates	IT governance record	7 years
Just-in-time activations	Entra audit log	Per tenant retention, exported quarterly
Quarterly review outcomes	Tier 4 record	7 years
Break-glass tests and rotations	Sealed record + Tier 4	7 years
Break-glass sign-ins	Incident record	7 years
Recovery-key read permission holders, reviewed quarterly	IT governance record	3 years

11. Related documents

ID	Title	Relationship
ACC-03	MFA Enrollment, Reset & Account Recovery	§4, and Wave 0 of the phishing-resistant rollout.
ACC-06	Identity Verification	§8 — V1 or V2 only for privileged accounts.
ACC-02	Account Naming Standard	The naming pattern in §3.
ACC-01	Account Lifecycle	Privileged removal on separation and role change.
ACC-08	Service, Application & Non-Human Account Standard	Non-human privilege, which is governed separately.
ACC-11	Vendor, Contractor & Consultant Account Standard	Vendor administrative access.
ACC-17	Periodic Access Review	Consumes §8.
DEV-03	Disk Encryption & BitLocker Recovery Keys	§7 — who may read a key.
DEV-12	Local Administrator Rights on Endpoints	The endpoint equivalent of this document.
M365-21	Tenant Configuration Change Control	Where privileged changes are recorded.
GOV-03	Security Incident Response	Break-glass use, and privileged account compromise.

Appendix A — Privileged account checklist

✓	Before the role is assigned	Evidence
☐	Separate administrative identity exists, not the staff account	Account name
☐	Not mail-enabled	Confirmed
☐	Phishing-resistant method registered — no SMS, no voice	Method
☐	Narrowest role that does the job, not Global Administrator by default	Role name
☐	Just-in-time eligibility rather than standing assignment, where supported	Activation model
☐	Tier 4 approved, with a reason	Approver + reason
☐	End date recorded, or “ongoing” stated explicitly	Date or note
☐	Added to the quarterly review register	Register entry
☐	Holder has read §7 — sign in, do the task, sign out	Confirmed

Part of the Known Good SOP Catalog by Kevin Zelman, written for small IT shops, contractors and consultants, career-changers and help desk technicians. Adapt the names, tiers and times to your own shop: the times here are cushion, not a promise.